Approach Paper – Methodology for the Risk Rating of Audit Findings & Reports

1. Introduction

The purpose of this document is to define the methodology for the risk rating of audit findings and audit reports. This methodology has been designed in alignment with the risk rating methodologies adopted by the other assurance functions in the Bank (Operational Risk and Compliance Assurance) ensuring consistent and transparent risk assessment and reporting.

2. Audit Finding Risk Rating Framework

Audit Findings are risk assessed and assigned a severity level based on the following factors:

Financial Impact	Non-Financial Impact	Likelihood
Potential financial loss to the bank.	Includes regulatory, operational, reputational, credit, market, liquidity, and strategic transformation risks.	The probability of the risk materializing based on actual sample observations.
Final Risk Rating – The highest impact rating determines the final classification of the audit finding.		

3.1 Risk Grading Matrix** (Impact)

GIA in alignment with risk rating methodology adopted by the other relevant assurance functions in the Bank intends to transition to a four-scale risk level grading matrix which considers both **impact and likelihood** (financial and non-financial) to determine the severity of audit findings:

Risk Level		Low	Medium	High		Very High*
Financial Impact (AED)		< 200K	200K - 5M	5M - 10M	10M - 20M	> 20M
Non - Financial Impact Scale		Negligible	Minor	Moderate	Significant	Material
Non-Financial Impact	**Regulatory, Compliance & Legal Risk**	Minor regulatory deviation, no legal liability	Regulatory observations requiring corrective action	Significant regulatory breaches, risk of penalties		Severe violations, large fines, potential license revocation
	Operational, System, Employees & Third-Party Risk	Minor process inefficiencies, no impact on operations	Process weaknesses needing enhancement, minor disruptions	Major operational failures, IT security gaps, vendor failures		Critical IT system failures, large-scale fraud, business shutdown
	Customer, Reputation & Conduct Risk	No significant complaints or reputational damage	Limited reputation impact, minor service failures	Widespread reputational damage, regulatory scrutiny		Major reputational crisis, Central Bank intervention
	Credit & Counterparty Risk	Minor policy deviations	Credit process exceptions, minor borrower downgrades	Portfolio-wide deterioration, major borrower downgrades		Systemic credit deterioration, widespread defaults, regulatory intervention
	Liquidity & Market Risk	Minor observation in risk monitoring	Deficiencies in liquidity/market risk reporting, within appetite	Governance failures in risk management, reporting deficiencies		Breach of liquidity and market risk limits, regulatory intervention
	Strategy & Transformation Risk	Minor project delays, no regulatory impact	Deficiencies in strategic execution, cost overruns	Regulatory-driven project risks, major business model failures		Failure of major strategic initiatives, systemic impact on business

*** Very High Risk category** has been introduced to capture risks with critical financial, regulatory, or reputational consequences. This ensures that significant risks are escalated immediately and addressed with the highest priority.

** Please refer to **Annexure 1** for complete detailed Risk Grading Impact Matrix.

*** In case a risk has multiple impacts, the highest impact is used to assess the risk rating.

3.1.1 Enhanced Non-Financial Risk Coverage

In addition to the risks considered by Operational risk and Quality Assurance (Compliance) in their methodology, GIA's methodology incorporates a broader range of risk categories to support the extensive nature of audit work, such as:

- Credit and counterparty risk
- Liquidity and market risk
- Strategy execution and transformation risk
- Conduct risk

3.1.2 Likelihood Considerations

Likelihood reflects the estimated frequency or probability of a risk materializing and is a key dimension in determining overall audit finding severity—alongside impact. It provides a forward-looking view of risk exposure and helps prioritize management action.

Likelihood is assessed through:

- Professional judgment based on control breakdowns, recurrence potential, or nature of the issue
- Historical incident data or previous audit results
- Exception rates observed in reviewed samples, where applicable

When sampling has been performed, likelihood can be quantified based on sample results:

Likelihood Category	Percentage of Sampled Items with Issues	Frequency Interpretation
Material	> 50% (More than half of the sample)	widely spread issue, requiring urgent action.
Significant	31% - 50%	High frequency, requiring management attention.
Moderate	11% - 30%	Some occurrences, but not widespread.
Minor	1% - 10%	Isolated instances, may indicate process weaknesses.
Negligible	<1%	Extremely infrequent, minimal concern.

*Likelihood when paired with impact, determines the final audit finding rating using the matrix outlined below:

3.3 Risk Rating of Audit Findings

Audit finding ratings are derived by applying the **impact** and **likelihood** assessments to the integrated risk matrix below, coupled with the professional judgement of the Internal Audit team. This structured approach ensures consistency and transparency in how audit finding severity is classified across all audits.

Likelihood Scale / % Sample					
Once a Month or Higher **>=50%**					
At-least once a Quarter **31-50%**					
At-least once a half year **11-30%**					
At-least once a Year **1-10%**					
Once in 5 years or lower **<=1%**					
Financial Loss Impact Scale	≤ AED 200K	>AED 200K and ≤AED 5 million	>AED 5 million & ≤AED 10 million	> AED 10 million & ≤AED 20 million	> AED 20 million
Non-Financial Impact Scale	**Negligible**	**Minor**	**Moderate**	**Significant**	**Material**

Each risk is assessed based on likelihood and impact (financial and non–financial) to provide a rating to the risk^

^In case a risk has multiple impacts, the highest impact is used to assess the risk rating

The risk assessment derived from the matrix above will determine **Audit Finding Rating** as follows:

Audit Finding Rating	Definition
Very High (VH)*	Risks with critical regulatory, financial, or reputational consequences. May include severe violations, large-scale fraud, major data breaches, or regulatory penalties that threaten business continuity or license to operate. Typically requires immediate escalation to GCEO, senior management, the Board of Directors, and urgent, coordinated remediation efforts.
High (H)	Risks that have already materialized or are expected to materialize with significant adverse financial, reputational, regulatory, or legal impact. Examples include fraud, non-compliance with critical policies or procedures, or control weaknesses that significantly affect strategic objectives. Prompt senior management attention and corrective action are required.
Medium (M)	Risks that have materialized with minimal adverse impact, or are expected to materialize with moderate financial, reputational, regulatory, or legal implications. Typically includes process-level control weaknesses or gaps in policies that require improvement but do not pose an immediate threat to business continuity or objectives.
Low (L)	Risks that have materialized with negligible adverse impact, or are expected to materialize with minimal financial, reputational, regulatory, or legal consequences. Control weaknesses are unlikely to result in material loss or significantly affect the accuracy of results or operational effectiveness. Action may still be needed, but with lower urgency.

* The addition of this category ensures alignment with the methodology adopted by the **second lines of defence**, reflecting the highest level of exposure requiring immediate escalation.

4. Audit Report Rating Framework

4.1 Rating Categories

Audit report rating framework provides a structured approach for the rating of the overall audit report based on the level of adequacy and effectiveness of the key controls assessed during the audit.

Overall Audit Report Rating Categories

Rating	Definition
Satisfactory	Key controls are appropriately designed and operating effectively. A few minor exceptions may be noted but the impact is contained and should not affect the successful achievement of business objectives. There is also reasonable assurance that the control environment can accommodate an increased level of operations without adverse impacts.
Needs Improvement	Overall, key controls are well defined, but weaknesses are noted in control design or operating effectiveness, which are expected to have limited to moderate impact with the current level of operations. Corrective actions are required and should be completed ahead of any planned increases in business volumes.
Needs Significant Improvement	Wide-ranging weaknesses were noted in the existence, design and operation of key controls which could have a significant impact at a divisional level. Escalation to senior management is expected and as a priority action should be taken by management to remediate and enhance the control environment.
Unsatisfactory	The control environment fails to support business objectives and manage risks. Weaknesses noted in control design, operation and existence could have a severe impact on the Bank's operations and reputation and may result in a material financial loss. Control gaps persist across the Bank and require immediate senior management attention to resolve.
Unrated	The report may constitute a special review or may be advisory in nature. All process and controls weaknesses assessed as a part of this review are individually risk rated, and management's remedial actions should be prioritised and commensurate with assigned risk rating.

4.2 Quantitative and Qualitative Scoring Model

The final audit rating is derived from a weighted scoring system and qualitative considerations. The quantitative score provides a baseline assessment, while qualitative factors ensure a holistic evaluation of risks taking into account GIA professional judgement.

4.2.1 Weighted Scoring System

Very High (VH) Issue:	High (H) Issue:	Medium (M) Issue:	Low (L) Issue:
4 points	3 points	2 points	1 point

Thresholds for Final Ratings:

The following thresholds are used to determine the overall audit report rating based on the combined score (of all audit findings) and qualitative considerations:

Total Score	Rating Category	Criteria & Additional Qualitative Considerations
0 – 10	**Satisfactory**	**No high-rated issues**; minor exceptions noted but do not impact overall control effectiveness.
11 – 25	**Needs Improvement**	**At least 1 high rated** issues or **multiple medium-rated** issues with low-moderate impact.
26 – 34	**Needs Significant Improvement**	**Multiple high/medium-rated issues** requiring management escalation.
>35	**Unsatisfactory**	**Widespread control deficiencies** with significant business risk.

4.2.2 Qualitative Considerations

While the scoring model provides a baseline, professional judgment is crucial. The following factors should be considered:

- **Repeat Findings:** Recurrent issues from previous audits increase the severity of risk.
- **Regulatory Exposure**: Findings with regulatory implications may warrant a higher rating.
- **Management Responsiveness:** A strong, well-defined action plan and or mitigating controls in place / may lessen the severity of a rating.
- **Extent of Impact:** A single high/very high-rated issue affecting the entire bank may warrant a more severe rating.
- **Significance of Issues:** The impact of control failures across business operations.

4.2.3 Rating Overrides

The final audit rating may be adjusted upward or downward based on a comprehensive assessment of both **quantitative and qualitative factors**.

- Ratings will be determined by the end of fieldwork/ reporting stage & discussed with auditees.
- Any override must be clearly documented, justified by the Audit Manager and approved by the **Group Chief Audit Officer (GCAO)**;
- Rating disputes should be resolved at the Draft report stage between the Audit Manager and Auditee;
- If unresolved, the matter is escalated to the Group Chief Audit Officer (GCAO) for final decision.

4.2.4 Alignment with Two-Tier Audit Report Rating System

To further enhance audit reporting and align with the industry best practices, GIA is piloting a Two-Tier Audit Report Rating System which will encompass the following:

- Tier 1: Control Environment Rating – Anchored in the current audit report rating methodology outlined in this document, it assesses the adequacy and effectiveness of internal controls based on the nature, severity, and volume of audit findings.
- Tier 2: Management Control Awareness Rating – Evaluates management's awareness, ownership and proactive identification and remediation of control issues.

The model is currently under pilot validation, with full implementation targeted for September 2025. Once finalized, it will be integrated into GIA's audit methodology reporting practices to provide a holistic assessment of both control adequacy/ effectiveness and Management awareness thereof.

5. Governance

✓ The revised risk assessment methodology will be implemented immediately upon endorsement by the Board Audit Committee.

✓ The revised issue risk rating methodology will be formally documented in the **GIA Manual** in its scheduled update in June 2025.

Annexure1: GROUP INTERNAL AUDIT – DETAILED RISK GRADING MATRIX

Risk Type		Low	Medium	High		Very High
Financial Impact (AED)		< 200K	200K - 5M	5M - 20M		> 20M
Non - Financial Impact Scale		Negligible	Minor	Moderate	Significant	Material
Non-Financial Impact	**Regulatory, Compliance & Legal Risk**	- Very minor misalignment with CBUAE/ other Regulators requirements - Little or no impact - No Legal Liability - Immaterial policy deviation - Minor process documentation issue	- Missed or error in regulatory reporting - Regulatory observation requiring further action from Management - Policy deviation with a limited to moderate impact - Non-compliance with a significant regulatory requirement (AMLCFT and others) - Minimal Legal Liability	- Significant/ recurrent inaccurate reporting to the Regulator - Possibility of a legal action against the Bank with a significant financial impact - Regulatory breach which may lead to fines - Significant policy deviation - Regulatory intervention (Central Bank targeted reviews) - Lack of policy or/and process with respect to regulations		- Legal action against the Bank with a major impact - Warning from regulator stating repetition of event(s) - Severe regulatory violation resulting in fine or penalties in relation to AMLCFT and other regulations - License revocation risk or business restrictions - Board-level intervention required - Systemic policy/process breaches
	Operational, System, Employees and Third Party Risk	- Minor process inefficiencies - Isolated instances of employee non-compliance with bank policies/ procedures that do not result in regulatory breaches or financial losses - No discernible disruption to business processes or systems - Minor process documentation issue	- Process weaknesses requiring enhancements - Employee misconduct (without fraud) - Third-party/vendor SLA breaches - Business disruptions recoverable within RTO (Recovery Time Objective) - Major process documentation issue	- Material operational failures impacting business continuity - IT security gaps exposing data risks - Employee fraud cases requiring investigation - Major vendor/service provider failures - Business disruptions across multiple units, unable to recover within RTO (Recovery Time Objective)		- Critical IT system failure (data loss, business shutdown, Financial impact - Large-scale fraud/internal misconduct - Third-party/vendor failure causing regulatory action - Complete business stoppage, unable to recover within RTO (Recovery Time Objective)
Non-	**Customer, Reputation & Conduct Risk**	- No significant customer complaints or reputational risks	- Reputation impact limited to internal/external complaints	- Reputation damage through widespread customer		- Bank-wide reputational crisis (e.g., fraud, AML breach, with Financial impact)

Risk Type		Low	Medium	High		Very High
Financial Impact (AED)		< 200K	200K - 5M	5M - 20M		> 20M
Non - Financial Impact Scale		Negligible	Minor	Moderate	Significant	Material
		- Isolated cases of misalignment with Conduct Risk Framework - No publicity and/or minor short term damage - Minor process documentation issue	- Minor service failures leading to complaints - Minor breaches in ethical standards - Short term damage - Major process documentation issue - Impact to <1% of customer base	complaints with Financial impact - Media attention due to misconduct or financial mis-selling - Regulatory involvement in customer complaints - Impact to >1% to <20% of customer base		- Negative media/social media coverage leading to Central Bank intervention - Conduct failure triggering regulatory fines and legal suits - Significant impact to >20% of customer base
	Credit & Counterparty Risk	- Isolated credit policy deviation with no financial impact - Minor deviations from lending process and procedures - Minor process documentation issue	- Exceptions with the established lending process requiring additional oversight - Slight rise in overdue loan payments, but still within the bank's acceptable risk thresholds - Downgrade of borrower risk grade - Issues relating to credit risk mitigations or covenants with a limited to moderate impact - Major process documentation issue	- Issues with credit governance including policy gaps impacting credit risk assessment - Major exceptions with the established lending process - Downgrade of large borrower (group of borrowers) - Portfolio-wide increase in NPLs beyond risk appetite - Credit risk concentration (name, sector and others) emerging beyond risk appetite are emerging - Deterioration in portfolio quality (>1% to <10% of total portfolio)		- Widespread credit defaults impacting capital adequacy with material Financial impact - Regulatory intervention due to failing asset quality - Severe underwriting lapses leading to major financial risk - Systemic deterioration in portfolio quality (>10%)

Risk Type		Low	Medium	High		Very High
Financial Impact (AED)		< 200K	200K - 5M	5M - 20M		> 20M
Non - Financial Impact Scale		Negligible	Minor	Moderate	Significant	Material
Non-Financial Impact	**Liquidity & Market Risk**	- Minor observations noted in the calculation, reporting and monitoring of market, liquidity and interest rate risks metrics - No impact on compliance with the risk appetite metrics and regulatory limits - Minor process documentation issue	- Deficiencies in the calculation and monitoring of market, liquidity and interest rate risk metrics with limited to moderate impact. - Deterioration of the liquidity and market risk metrics, but they remain within risk appetite - Major process documentation issue	- Shortcomings in risk governance including non-compliance with the established policies. - Deficiencies in the calculation and reporting of market and liquidity risk metrics which impacts the decision-making process. - Significant liquidity pressure and market risk losses beyond the Bank's risk appetite		- Breach of liquidity and market risk regulatory limits - Regulatory intervention due to major deficiencies of the Bank's processes relating to management of market and liquidity risk - Systemic risk event causing major financial losses
	Strategy & Transformation Risk	- Minor delays in non-strategic projects with no regulatory impact - No deviation from transformation roadmap - Minor process documentation issue	- Delays in execution of strategic initiatives and projects - Deficiencies in monitoring strategy execution and projects - Deficiencies in the financial management of projects	- Regulatory-driven transformation project gaps - Significant cost overruns in major projects - Business model risks due to poor strategy execution		- Failure in execution of a major project - Major and structural issues in project governance and delivery - Breach of the capital adequacy risk appetite limit